

S11/L2

Esercizio Analisi Statica

Traccia

Lo scopo dell'esercizio di oggi è di acquisire esperienza con IDA, un tool fondamentale per l'analisi statica. A tal proposito, con riferimento al malware chiamato «Malware_U3_W3_L2 » presente all'interno della cartella «Esercizio_Pratico_U3_W3_L2 » sul Desktop della macchina virtuale dedicata all'analisi dei malware, rispondere ai seguenti quesiti, utilizzando IDA Pro.

1. Individuare l'indirizzo della funzione DLLMain (così com'è, in esadecimale)
2. Dalla scheda «imports» individuare la funzione «gethostbyname». Qual è l'indirizzo dell'import? Cosa fa la funzione?
3. Quante sono le variabili locali della funzione alla locazione di memoria 0x10001656?
4. Quanti sono, invece, i parametri della funzione sopra?
5. Inserire altre considerazioni macro-livello sul malware (comportamento)

1. Indirizzo della funzione DLLMain

Dopo aver aperto il malware con il tool IDA usiamo la barra spaziatrice per passare da una visualizzazione grafica a una pura del codice assembly. Da qui, possiamo vedere l'indirizzo esadecimale della funzione DLLMain, ovvero **1000D02E**.

```
.text:1000D02E DllMain@12      proc near
```

2. Funzione «gethostbyname»

Nella scheda «imports» cerchiamo la funzione «gethostbyname».

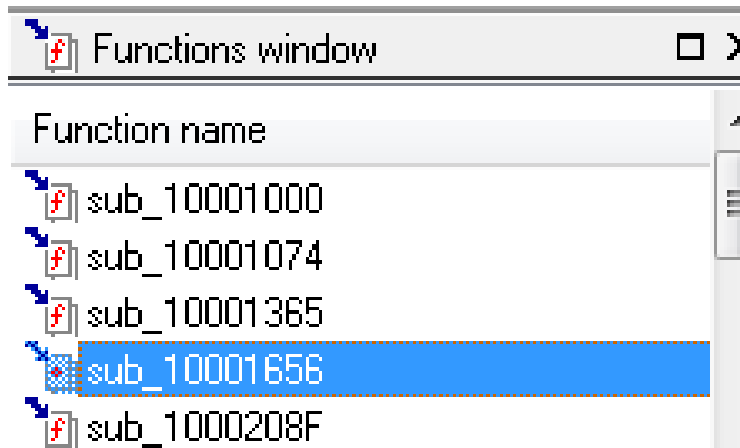
Offset	Import Name	Library Name
00000000100163CC	52 gethostbyname	WS2_32

L'indirizzo esadecimale dell'import della funzione è **00000000100163CC**.

La funzione «gethostbyname» fa parte della libreria **WS2_32**. La funzione viene utilizzata per risolvere un nome di dominio o un nome host in un indirizzo IP (DNS).

3. Variabili della funzione alla locazione di memoria 0x10001656

Tramite la finestra delle funzioni selezioniamo la funzione alla locazione di memoria 0X10001656.



Nella finestra IDA View-A vediamo le seguenti variabili.

```
.text:10001656 var_675      = byte ptr -675h
.text:10001656 var_674      = dword ptr -674h
.text:10001656 hLibModule    = dword ptr -670h
.text:10001656 timeout      = timeval ptr -66Ch
.text:10001656 name         = sockaddr ptr -664h
.text:10001656 var_654      = word ptr -654h
.text:10001656 Dst         = dword ptr -650h
.text:10001656 Parameter    = byte ptr -644h
.text:10001656 var_640      = byte ptr -640h
.text:10001656 CommandLine  = byte ptr -63Fh
.text:10001656 Source       = byte ptr -63Dh
.text:10001656 Data         = byte ptr -638h
.text:10001656 var_637      = byte ptr -637h
.text:10001656 var_544      = dword ptr -544h
.text:10001656 var_50C      = dword ptr -50Ch
.text:10001656 var_500      = dword ptr -500h
.text:10001656 Buf2         = byte ptr -4FCh
.text:10001656 readfds      = fd_set ptr -4BCh
.text:10001656 phkResult    = byte ptr -3B8h
.text:10001656 var_3B0      = dword ptr -3B0h
.text:10001656 var_1A4      = dword ptr -1A4h
.text:10001656 var_194      = dword ptr -194h
.text:10001656 WSADATA      = WSADATA ptr -190h
```

4. Parametri della funzione alla locazione di memoria 0x10001656

Tenendo come riferimento quanto fatto nel punto 3 possiamo notare che sotto le variabili della funzione vi è anche un parametro, ovvero **arg_0**.

```
.text:10001656 arg_0        = dword ptr 4
```

5. Comportamento del Malware

Tramite le varie finestre di IDA ho raccolto le seguenti informazioni:

- Nella finestra «strings» troviamo un url posizionato nella sezione data

```
"..."_data:1001... 0000002E C [This is RDC]pics.practicalmalwareanalysis.com
```

- Sempre nella stessa finestra ho trovato le seguenti stringhe

```
xdoors_d:1... 00000118 C Hi,Master [%d/%d/%d %d.%d.%d]\n\nWelCome Back...Are You Enjoying To...
```

Aprendo la sezione corrispondente in IDA View-A troviamo queste stringhe

```
xdoors_d:10095B44 db 'WelCome Back...Are You Enjoying Today?',0Dh,0Ah
xdoors_d:10095B44 db 0Dh,0Ah
xdoors_d:10095B44 db 'Machine UpTime [%-.2d Days %-.2d Hours %-.2d Minutes %-.2d Secon'
xdoors_d:10095B44 db 'ds]',0Dh,0Ah
xdoors_d:10095B44 db 'Machine IdleTime [%-.2d Days %-.2d Hours %-.2d Minutes %-.2d Seco'
xdoors_d:10095B44 db 'nds]',0Dh,0Ah
xdoors_d:10095B44 db 0Dh,0Ah
xdoors_d:10095B44 db 'Encrypt Magic Number For This Remote Shell Session [0x%02x]',0Dh,0Ah
xdoors_d:10095B44 db 0Dh,0Ah,0
```

Come possiamo leggere c'è un riferimento ad una **remote shell**.

La cosa sembra confermata anche dalla seguente parte di codice che va a chiamare il **cmd**

```
xdoors_d:10095B34 aCmd_exeC db '\cmd.exe /c ',0 ; DATA XREF: sub_1000FF58+27810
```

- Oltre alle stringhe che parlano di una remote shell, ho trovato un segmento del codice chiamato **xdoors_d**.

Effettivamente, andando a visualizzare la finestra «segmentation» di IDA troviamo il segmento

Name	Start	End	R	W	X	D	L	Align	Base	Type	Class	AD	es	ss	ds	fs	gs
.text	0000000010001000	0000000010016000	R	.	X	.	L	para	0001	public	CODE	32	0000	0000	0003	FFF...	FFF...
.idata	0000000010016000	0000000010016424	R	.	.	.	L	para	0002	public	DATA	32	0000	0000	0003	FFF...	FFF...
.rdata	0000000010016424	0000000010019000	R	.	.	.	L	para	0002	public	DATA	32	0000	0000	0003	FFF...	FFF...
.data	0000000010019000	0000000010093000	R	W	.	.	L	para	0003	public	DATA	32	0000	0000	0003	FFF...	FFF...
xdoors_d	0000000010093000	0000000010096000	R	W	.	.	L	para	0004	public	DATA	32	0000	0000	0003	FFF...	FFF...

Conclusioni

Tenendo in considerazione ciò che abbiamo visto anche nei punti precedenti dell'esercitazione, possiamo dedurre che il malware cerchi ottenere l'indirizzo IP di "pics.practicalmalwareanalysis.com" tramite la funzione «gethostbyname» e successivamente di creare una reverse shell verso il sito.